

1 · Token source — header wins

cookie: auth_token

Authorization: Bearer <token>
explicit client action → overrides cookie

2 · validateToken() — two providers, tried in order

a) custom backend JWT
jwt.verify(HS256, getJwtSecret())
secret from GCP Secret Manager

not a backend token

b) fallback: Firebase
fAuth.verifyIdToken()

ok

ok

load user + userMappings + organisation
+ course enrolments

3 · req.context assembled

{ userId, uid, orgId, tenantId, unitId,
role, accessScope, features }

tenantId = decoded.tenantId ?? user.tenant_id
← token wins = context switch
unitId = x-unit-id header ?? decoded.unitId ?? null
features = env flags + entity_features rows (DB)

4 · legacy twin — set unconditionally, CAN DISAGREE

req.user_id · req.organisation_id · req.user
req.tenantId = user.tenant_id (NOT the switched one)

next() — ALWAYS called, even with no/invalid token.
The middleware authenticates; requireAuth() is what REJECTS.